

Security+ 2.3 · Supply Chain Vulnerabilities

Mestre CyberSec — PDF baseado na aula do Professor Messer · 2.3 — Supply Chain Vulnerabilities (9:12) · [vídeo original ↗](#) · [YouTube ↗](#)

Atacar o ELO que tu confias: software comprometido (SolarWinds), componente de terceiros, chip de hardware malicioso, library de código (npm/pip), open-source package sem dono claro. O atacante injeta código no CANAL CONFIÁVEL — todo mundo baixa espalha pra ele. Defesa: SBOM (lista de ingredientes), code signing, SCA (checa vulnerabilidade em library), verificação de fonte.

💡 Highlights que a prova cobra

- Supply chain: o atacante usa o CANAL CONFIÁVEL pra entrar
- SolarWinds: o caso clássico (18k empresas)
- SBOM = Software Bill of Materials — lista de componentes do software

🎯 Dicas de prova

- 'list of software components' = SBOM
- 'checks dependencies for known vulnerabilities' = SCA

Cenário clássico: Cenário: 'library de npm comprometida afeta todo mundo que usa o pacote' = supply chain vulnerability.

✅ Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Comprometer um fornecedor de software pra atingir todos os clientes dele (ex: SolarWinds):

- A)** Ataque de cadeia de suprimentos
- B)** Watering hole
- C)** Insider
- D)** Zero-day

2. Cenário corporativo (Supply Chain Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Supply chain: o atacante usa o CANAL CONFIÁVEL pra entrar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Supply chain: o atacante usa o CANAL CONFIÁVEL pra entrar...

3. Cenário corporativo (Supply Chain Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'SolarWinds: o caso clássico (18k empresas)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: SolarWinds: o caso clássico (18k empresas)...

4. Cenário corporativo (Supply Chain Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'SBOM = Software Bill of Materials — lista de componentes do software'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: SBOM = Software Bill of Materials — lista de componentes do software...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Supply Chain Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'list of software components' = SBOM'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'list of software components' = SBOM...

6. Cenário corporativo (Supply Chain Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'checks dependencies for known vulnerabilities' = SCA'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'checks dependencies for known vulnerabilities' = SCA...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Supply Chain Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Cenário: 'library de npm comprometida afeta todo mundo que usa o pacote' = supply chain vulnerability.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Cenário: 'library de npm comprometida afeta todo mundo que usa o pacote' = ...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Supply Chain Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Supply chain: o atacante usa o CANAL CONFIÁVEL pra entrar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Supply chain: o atacante usa o CANAL CONFIÁVEL pra entrar...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Supply Chain Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'SolarWinds: o caso clássico (18k empresas)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: SolarWinds: o caso clássico (18k empresas)...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Supply Chain Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'SBOM = Software Bill of Materials — lista de componentes do software'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: SBOM = Software Bill of Materials — lista de componentes do software...

GABARITO COMENTADO

- 1) A — Ataque de cadeia de suprimentos.** Supply chain attack compromete um elo confiável (fornecedor) pra alcançar muitos alvos de uma vez.
- 2) D — Implementar a solução correspondente: Supply chain: o atacante usa o CANAL CONFI.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Supply Chain Vulnerabilities): Supply chain: o atacante usa o CANAL CONFIÁVEL pra entrar. As demais alternativas configuram violações g
- 3) D — Implementar a solução correspondente: SolarWinds: o caso clássico (18k empresas).** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Supply Chain Vulnerabilities): SolarWinds: o caso clássico (18k empresas). As demais alternativas configuram violações graves de confor
- 4) A — Implementar a solução correspondente: SBOM = Software Bill of Materials — lista .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Supply Chain Vulnerabilities): SBOM = Software Bill of Materials — lista de componentes do software. As demais alternativas configuram
- 5) D — Implementar a solução correspondente: 'list of software components' = SBOM....** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Supply Chain Vulnerabilities): 'list of software components' = SBOM. As demais alternativas configuram violações graves de conformidade
- 6) A — Implementar a solução correspondente: 'checks dependencies for known vulnerabili.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Supply Chain Vulnerabilities): 'checks dependencies for known vulnerabilities' = SCA. As demais alternativas configuram violações grave
- 7) C — Implementar a solução correspondente: Cenário: 'library de npm comprometida afet.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Supply Chain Vulnerabilities): Cenário: 'library de npm comprometida afeta todo mundo que usa o pacote' = supply chain vulnerability..
- 8) B — Implementar a solução correspondente: Supply chain: o atacante usa o CANAL CONFI.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Supply Chain Vulnerabilities): Supply chain: o atacante usa o CANAL CONFIÁVEL pra entrar. As demais alternativas configuram violações g
- 9) C — Implementar a solução correspondente: SolarWinds: o caso clássico (18k empresas).** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Supply Chain Vulnerabilities): SolarWinds: o caso clássico (18k empresas). As demais alternativas configuram violações graves de confor
- 10) D — Implementar a solução correspondente: SBOM = Software Bill of Materials — lista .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Supply Chain Vulnerabilities): SBOM = Software Bill of Materials — lista de componentes do software. As demais alternativas configuram

